Laporan Audit Keamanan – CertiChain

Mata kuliah: Blockchain (KP70067008) · **UAS TA 2026/2027 Ganjil** · Universitas Siliwangi
Objek audit: `contracts/audit/CertiChainV1.sol` (baseline, vulnerable-by-design) → `contracts/CertiChain.sol` (v2, hasil perbaikan)
Compiler/alat: solc 0.8.24 (optimizer 200), Hardhat 2.22.17, ethers 6.13.4, Slither (analisis statis), solidity-coverage 0.8.14
Jaringan uji: Hardhat local network, chain ID 31337 (tanpa aset nyata)
Jejak commit: baseline `1caf3a8` → PoC eksploit `5b6ae73` → perbaikan + retest `713466f` → deploy/integrasi `0ebe60b`

> Catatan metodologi: V1 ditulis sebagai baseline yang **sengaja memuat pola kerentanan umum** agar efektivitas mitigasi dapat dibuktikan secara terukur (PoC sebelum, retest sesudah). Audit ini adalah audit mandiri tim, bukan pengganti audit profesional.

1. Threat model ringkas

Unsur	Uraian
Aset yang dilindungi	(1) Integritas catatan sertifikat (hash, issuer, holder, status); (2) dana stake issuer (ETH uji); (3) peran ADMIN/ISSUER; (4) ketersediaan fungsi verifikasi dan pencabutan.
Aktor	Admin (tata kelola); Issuer jujur; Issuer jahat/ter-kompromi; Holder; Verifier publik; Penyerang eksternal (EOA/kontrak jahat); Block builder/MEV searcher (mengurutkan transaksi).
Trust boundary	(a) Off-chain ↔ on-chain: isi PDF tidak dipercaya, hanya hash yang dicatat; (b) Wallet/provider ↔ kontrak: tanda tangan transaksi; (c) Kontrak ↔ kontrak penerima ETH (panggilan eksternal pada penarikan); (d) Admin ↔ issuer (otoritas penangguhan/sanksi); (e) Mempool publik (urutan transaksi tidak dijamin).
Skenario penyalahgunaan	S1 issuer jahat menguras stake issuer lain via reentrancy; S2 issuer mencabut sertifikat pesaing; S3 issuer menyerobot hash sebelum issuer sah (front-running); S4 spam sertifikat ke satu holder sehingga pencabutan massal gagal; S5 input tidak valid mencemari registri; S6 dana terkunci karena transfer gagal; S7 manipulasi waktu blok untuk status kedaluwarsa.

2. Cakupan pemeriksaan

Aspek wajib	Relevansi	Hasil
Reentrancy	Relevan (penarikan ETH)	A-01 (V1) → diperbaiki
Access-control flaw	Relevan	A-02 (V1) → diperbaiki
Front-running / transaction ordering	Relevan (ID sertifikat)	A-03 (V1) → diperbaiki
Oracle risk	Tidak ada oracle/feed eksternal; hanya `block.timestamp`	A-06 informasional, diterima
DoS	Relevan (loop tak terbatas)	A-04 (V1) → diperbaiki
Validasi input	Relevan	A-05 (V1) → diperbaiki
Error handling	Relevan (low-level call)	A-07 (V1) → diperbaiki

3. Tabel audit temuan

Skala: **Dampak** (Rendah/Sedang/Tinggi) × **Kemungkinan eksploitasi** (Rendah/Sedang/Tinggi) → **Risiko**.

ID	Temuan & lokasi	Bukti	Dampak	Kemungkinan	Risiko	Mitigasi (V2)	Status verifikasi
A-01	Reentrancy pada `withdrawStake()` – transfer ETH sebelum `stakeOf = 0`, tanpa guard (V1:56-62)	PoC-A-01: attacker setor 1 ETH, akhir saldo 3 ETH, kontrak 0 ETH; Slither `reentrancy-eth`	Tinggi (kehilangan seluruh dana stake)	Tinggi (siapa pun bisa deploy penyerang)	**Tinggi**	Checks-Effects-Interactions (`stakeOf=0` sebelum call) + modifier `nonReentrant`	**Terverifikasi** – T-30: serangan revert `TransferFailed`, saldo kontrak tetap 2 ETH; Slither: tidak ada `reentrancy-*` pada V2
A-02	Access-control flaw: `revokeCertificate` hanya memeriksa `ISSUER_ROLE`, tidak memeriksa penerbit asli (V1)	PoC-A-02: issuer B mencabut sertifikat issuer A	Tinggi (kepercayaan registri runtuh)	Sedang (butuh peran issuer & stake)	**Tinggi**	Hanya `c.issuer` atau `ADMIN_ROLE`; selain itu revert `NotAuthorized`	**Terverifikasi** – T-24, T-28 (batch atomik)
A-03	Front-running/ordering: ID = `docHash`; issuer lain dapat menyerobot hash (holder salah, penerbitan sah revert) (V1)	PoC-A-03: holder tercatat = korban, penerbitan A revert `AlreadyIssued`	Sedang	Sedang (mempool publik)	**Sedang**	`id = keccak256(issuer, docHash)` (`CertLib.computeId`) sehingga ruang ID per-issuer	**Terverifikasi** – T-18: kedua sertifikat terbit dengan ID berbeda
A-04	DoS: `revokeAllForHolder` melakukan loop tak terbatas; getter mengembalikan array penuh (V1)	PoC-A-04: gas 10 sert.=125.165; 200 sert.=2.000.477; ≈9.870 gas/sertifikat → ±3.039 sertifikat melampaui blok 30 M gas	Sedang (pencabutan massal tak dapat dieksekusi)	Sedang (issuer dapat spam ke satu holder)	**Sedang**	`revokeBatch` dibatasi `MAX_BATCH=50`; getter berpaginasi (`offset,limit`)	**Terverifikasi** – T-27 (50 sukses, 51 revert `BatchTooLarge`), T-29
A-05	Validasi input: V1 menerima `holder=0`, `docHash=0`, expiry masa lalu	PoC-A-05: entri sampah tercatat	Rendah	Tinggi	**Rendah**	Custom error `InvalidHash`, `ZeroAddress`, `InvalidExpiry`	**Terverifikasi** – T-15, T-16 (batas tepat timestamp)
A-06	Ketergantungan `block.timestamp` untuk kedaluwarsa; tidak ada oracle eksternal	Slither `timestamp`	Rendah (deviasi detik)	Rendah	**Informasional**	Diterima: toleransi kedaluwarsa dalam skala hari/tahun; tidak dipakai untuk keputusan finansial	Dicatat; T-21 menguji batas
A-07	Error handling: hasil `call` tidak diperiksa → saldo dinol-kan walau transfer gagal, dana terkunci (V1:59)	PoC-A-07: 1 ETH tertinggal di kontrak, `stakeOf=0`; Slither `unchecked-lowlevel`	Tinggi (dana terkunci permanen)	Rendah (butuh penerima yang menolak ETH)	**Sedang**	`if (!ok) revert TransferFailed()` – seluruh transaksi di-revert	**Terverifikasi** – T-31: revert, `stakeOf` tetap 1 ETH

Hasil analisis statis (Slither, 102 detektor, 9 kontrak) – ringkasan

- `reentrancy-eth`, `reentrancy-events`, `unchecked-lowlevel` → **hanya pada V1** (mengonfirmasi A-01 dan A-07).
- `arbitrary-send-eth` pada `CertiChain.withdrawSlashed` → **diterima (by design)**: fungsi hanya untuk ADMIN, tujuan dana ditentukan admin (governance), dilindungi `nonReentrant` dan pola CEI.
- `timestamp`, `low-level-calls` → informasional (A-06; low-level call dipakai dengan pengecekan hasil). Output lengkap: `docs/evidence/B-slither-all.txt`.

4. Perubahan kode utama (V1 → V2)

1. `withdrawStake`: urutan **efek → interaksi**, `nonReentrant`, `require` hasil transfer (A-01, A-07).
2. `revokeCertificate`: otorisasi `msg.sender == c.issuer || ADMIN` (A-02).
3. `issueCertificate`: ID terikat issuer; validasi hash/holder/expiry (A-03, A-05).
4. `revokeBatch` (maks 50) menggantikan `revokeAllForHolder`; `getHolderCertificates` berpaginasi (A-04).
5. Tambahan tata kelola: `slash`, `LastAdmin` (cegah lockout), `setPaused` (pencabutan tetap diizinkan saat pause).

5. Retest dan cakupan

- Hasil `npx hardhat test`: **37 lulus, 0 gagal** (31 unit test V2 + 6 PoC V1) – `docs/evidence/B-test-output.txt`.
- Coverage (`npx hardhat coverage`) untuk `CertiChain.sol`: **statement 100 %, branch 90 %, function 100 %, line 100 %** – `docs/evidence/B-coverage-output.txt`.

6. Keterbatasan audit

- Audit mandiri tanpa fuzzing/formal verification; invariant (mis. total stake = saldo kontrak − slashedPool) dapat diuji dengan Echidna/Foundry pada tahap berikut.
- Admin tunggal adalah titik sentral (risiko tata kelola); rekomendasi multisig + timelock untuk produksi.
- Kontrak tidak upgradeable (disengaja); perubahan aturan memerlukan deploy baru dan migrasi.
- Front-end belum diuji otomatis di peramban dengan MetaMask.